

Report
Of
Secure Login System

Submitted

To

School of Computer Science and Engineering IILM University, Greater Noida, U.P.

In partial fulfilment of the requirement of degree of
B.Tech CSE



By

Roll Number of Student: 25scs1003000539

Name of Student: Priyanshu Pandey

Batch: 2 CSE24

2026-27

CANDIDATE'S DECLARATION

I, Priyanshu Pandey do hereby declare that the internship report titled ***Secure Login System*** has been completed by me to fulfil the requirement for the award of the degree of Bachelor of Technology in CSE. All the references have been quoted and I have not taken as such any material from any other source. I affirm to you that this report is my own and has not been submitted to any other institute for any degree/diploma requirement and further I shall be solely responsible for any kind of copyright violation in this regard.

priyanshu

signature

Student Name - Priyanshu Pandey

Roll No.-25scs1003000539

ACKNOWLEDGEMENT

I am using this opportunity to express my gratitude to everyone who supported me throughout the Internship Program. I am thankful for their aspiring guidance, invaluable constructive criticism and friendly advice during this work. I am sincerely grateful to them for sharing their truthful and illuminating views on a number of issues related to this work. I express my gratitude to my parents for their blessings.

priyanshu

signature

Student Name - Priyanshu Pandey

Roll No.-25scs1003000539

Chapter No.	Chapter Name	Page Nos.
	Cover Page	1
1.	Candidate's Declaration	2
2.	Acknowledgment	3
3.	Internship Completion Certificate	5
4.	Project Description 4.1 Introduction 4.2 Organization Profile 4.3 Problem Statement 4.4 Project Objectives 4.5 Scope of the Project 4.6 Technologies and Tools Used 4.7 System Architecture 4.8 Methodology 4.9 Expected Outcomes 4.10 Certificates of completion and other communication mail proof must be attached	6-9
5.	Bibliography/References	10

3) *INTERNSHIP COMPLETION CERTIFICATE*



4. PROJECT DESCRIPTION

4.1 Introduction

In web application development, authentication and user management form the primary defense against cyber threats. The Secure Login System project focuses on implementing key defensive mechanisms to guarantee user privacy and protection against common vulnerability vectors such as SQL Injection (SQLi), credential sniffing, brute-force attacks, and session hijacking.

<https://secure-login-system-server.vercel.app/>

4.2 Organization Profile

Thiranex (Skill Development & Future Tech) is an educational technology organization focused on practical, hands-on skill enhancement in emerging technical fields, including Cyber Security, Cloud Solutions, and Software Engineering. Through project-based learning and industry mentorship, Thiranex equips students with practical technical skills.

4.3 Problem Statement

Standard web application login portals frequently store credentials in plaintext or employ weak encryption, exposing user accounts to database leaks, rainbow table attacks, automated credential stuffing, and SQL Injection vulnerabilities.

4.4 Project Objectives

- Implement strong cryptographic hashing algorithms (bcrypt) with salt generation for user credentials.
- Develop robust server-side input validation and parameterized prepared statements to eliminate SQL Injection risks.
- Secure session state management through HTTP-only, secure, and samesite session cookies with session fixation countermeasures and explicit logout capabilities.
- Provide multi-factor defense capability through Time-based One-Time Password (TOTP) Two-Factor Authentication (2FA).
- Protect authentication endpoints from automated brute-force attempts using IP-based rate limiting.

4.5 Scope of the Project

The scope encompasses backend user authentication logic, relational database access layers, cryptographic password processing, user registration endpoints, session lifecycle management, security audit logging, and multi-factor validation integration.

4.6 Technologies and Tools Used

- **Frontend & Cloud Hosting:** HTML5/CSS3/JavaScript, Vercel Serverless Platform (<https://secure-login-system-server.vercel.app/>)
- **Backend Runtime & Framework:** Node.js, Express.js
- **Database:** SQLite (via node:sqlite) with Parameterized Prepared Statements
- **Cryptographic Libraries:** bcrypt (bcryptjs)
- **Session Management & Multi-Factor Auth:** Express-Session, Speakeasy (RFC 6238 TOTP), QRCode
- **Security & Defense Middleware:** Helmet (CSP, Clickjacking & MIME-type protection), Express-Rate-Limit (Brute-force mitigation), Validator.js
- **Testing Tools:** Automated Security Test Suite (Node.js), Postman, OWASP ZAP

4.7 System Architecture

- **Client Layer:** User Interface accepting login/registration inputs.
- **Validation Layer:** Sanitization middleware cleaning inputs against malicious scripts and parameter tampering.
- **Authentication Engine:** Cryptographic verification module validating passwords via salted hash comparisons.
- **Database Layer:** Storage engine retaining parameterized user metadata and hashed credentials.

4.8 Methodology

1. **Input Sanitization & Parameterization:** Enforced strict regex constraints, email normalization, and strictly parameterized SQL queries to completely neutralize SQL Injection vulnerabilities.
2. **Password Hashing:** Integrated bcrypt with a cryptographic work factor of 12 (4,096 iterations) and individual salts to protect against offline dictionary and rainbow table attacks.
3. **Session Handling:** Configured cryptographically random session identifiers with cookie attributes set to HttpOnly (mitigating XSS theft) and SameSite=Lax (mitigating CSRF), combined with session ID regeneration upon authentication to defeat session fixation.
4. **Two-Factor Authentication (2FA):** Implemented RFC 6238 TOTP protocols allowing users to bind authenticator apps (Google Authenticator, Microsoft Authenticator, Authy) via dynamic QR code generation.
5. **Defense-in-Depth Hardening:** Applied Helmet security headers (e.g. X-Frame-Options: DENY) and IP-based rate limiting on sensitive authentication routes.

4.9 Expected Outcomes

A robust, production-ready authentication web application that mitigates unauthorized access, resists database injection vectors, prevents session hijacking/fixation, throttles brute-force attempts, and ensures safe credential lifecycle management.

4.10 Certificates of Completion and Communication Proof



5. BIBLIOGRAPHY / REFERENCES

1. OWASP Foundation, "OWASP Top Ten Web Application Security Risks," OWASP Project, 2021. [Online]. Available: <https://owasp.org/www-project-top-ten/>
2. Grassi, P. A., et al., "Digital Identity Guidelines: Authentication and Lifecycle Management," NIST Special Publication 800-63B, National Institute of Standards and Technology, 2020.
3. Krawczyk, H., M'Raihi, D., Bellare, M., and Hoornaert, F., "TOTP: Time-Based One-Time Password Algorithm," Internet Engineering Task Force (IETF), RFC 6238, May 2011.
4. Provos, N. and Mazières, D., "A Future-Adaptable Password Scheme," in Proceedings of the 1999 USENIX Security Symposium, 1999. [Foundational paper for bcrypt]
5. Birkett, A., "Secure Authentication and Password Hashing Best Practices," IEEE Security & Privacy, vol. 21, no. 3, pp. 45–53, 2023.
6. Thiranex Skill Development & Future Tech, "Cyber Security Internship Program Documentation & Guidelines," 2026.